NEXTCORP - BİLGİ GÜVENLİĞİ VE BT ALTYAPISI DENETİM RAPORU

Denetlenen Kurum: NextCorp

Denetim Alanı: BT Altyapısı, Kimlik ve Erişim Yönetimi, Veri Güvenliği

Referans Standart: ISO/IEC 27001:2013 Ek A (Annex A) kontrolleri

Denetçi: Necdet Emre Bayraktar (Bilgi Sistemleri Denetçisi Adayı)

1. Yönetici Özeti

Bu rapor; AWS, şirket içi (On-Prem) sunucular, Google Workspace ve NextID kimlik yönetim platformundan oluşan hibrit bir BT altyapısına sahip olan ve ISO 27001 sertifikasyonunu hedefleyen NextCorp'un bilgi güvenliği denetim bulgularını içermektedir. Denetimde kurumun veri paylaşım ve yedekleme uygulamaları, kullanılan cihaz ve işletim sistemleri, NextID platformundaki kullanıcı hesapları, Ubuntu web sunucusu ile Fatura Onay Sistemi ve İnsan Kaynakları Portalı'ndaki yetkilendirmeler incelenmiştir.

Gerçekleştirilen inceleme sonucunda toplam 15 bulgu tespit edilmiştir: 3 Critical, 9 High ve 3 Medium. IT yöneticisi ve servis hesapları dahil kritik kullanıcılarda MFA'nın kapalı olduğu, aynı kullanıcının (emre.kaya) farklı sistemlerde hem IT Admin hem Yazılım Geliştirici olarak tanımlandığı, işten ayrılan bir personelin hesabının AWS ve Linux sunucusunda hala aktif olduğu, çalışan cihazlarının %30'unda ve bazı sunucularda (Windows Server 2012 R2, 2008 R2, Ubuntu 18.04 LTS) desteği sona ermiş işletim sistemleri kullanıldığı görülmüştür. Maaş verileri erişim kontrolü ve şifreleme olmayan Excel dosyalarında tutulmakta, kritik veriler haftalık ve manuel olarak USB belleklere yedeklenmekte, geri yükleme testi yapılmamaktadır.

Mevcut durum, NextCorp'un ISO 27001 sertifikasyon hedefinin önünde ciddi uygunsuzluklar bulunduğunu göstermektedir. Bulgular giderilmezse hesap ele geçirme, fidye yazılımı, veri sızıntısı ve KVKK kapsamında yaptırım riskleri yüksektir.

2. Denetim Kapsamı

Denetim, NextCorp'un BT altyapısını ve iş uygulamalarını aşağıdaki dört başlık altında kapsamaktadır:

- Sistem Hakkında: veri paylaşımı (USB, Google Drive), maaş yönetimi ve yedekleme süreçleri.
- Kullanılan Cihazlar ve Sistemler: çalışan cihazları, Windows Server 2012 R2 / 2008 R2, Ubuntu 18.04 LTS web sunucusu, macOS Ventura cihazları ve bulut / on-prem yönetim yapısı.
- NextID Yönetim Platformu: kullanıcı ve servis hesapları, MFA durumu ve erişim yetkileri.
- Ek Sistemler ve Yetkilendirme: Ubuntu sunucu kullanıcı yönetimi, Fatura Onay Sistemi ve İnsan Kaynakları Portalı yetkileri.

3. Yapılan Testler

- Çalışan cihazları ve sunucuların işletim sistemi sürümlerinin envanter üzerinden incelenmesi ve üretici destek durumunun kontrol edilmesi.
- NextID platformundaki kullanıcı listesinin rol, MFA durumu ve erişilen sistemler (Workspace, AWS, CRM, Payroll) açısından incelenmesi.
- Ubuntu 18.04 LTS web sunucusunda SSH yapılandırması (port), ufw güvenlik duvarı durumu, otomatik güncelleme ayarı ve sudo paket sürümünün kontrol edilmesi.
- /etc/passwd ve /etc/shadow dosyalarında kullanıcı listesi, home dizini atamaları, shell bilgisi ve parola hash formatının incelenmesi.
- Fatura Onay Sistemi ve İnsan Kaynakları Portalı'nda kullanıcı yetkilerinin görev tanımlarıyla karşılaştırılması.
- Veri paylaşım, maaş yönetimi ve yedekleme uygulamalarının yönetimle yapılan görüşmeler ve yöneltilen sorular (Ek-1) üzerinden değerlendirilmesi.

4. Tespit Edilen Bulgular

4.1 Sistem Hakkında

Bulgu 1 - Kontrolsüz Veri Paylaşımı ve Veri Sızıntısı Riski

- **ISO 27001 Referansı:** A.13.2.1 (Bilgi Transferi Politikaları ve Prosedürleri), A.8.3.1 (Taşınabilir Ortam Yönetimi)
- **Eksiklik:** USB bellek ve Google Drive üzerinden dosya paylaşımı kontrolsüz şekilde yapılmaktadır. Kurum içinde veri paylaşım politikası ve Veri Kaybını Önleme (DLP) çözümü bulunmamaktadır.
- **Neden:** Güvenli ve merkezi bir dosya paylaşım sistemi yerine çalışanlar manuel ve riskli yöntemler kullanmaktadır.
- **Etki:** Hassas şirket verileri yetkisiz kişilerin eline geçebilir. Bu durum KVKK uyumsuzluğuna, veri sızıntılarına ve itibar kaybına yol açabilir.
- **Öneri:** USB bellek kullanımı kısıtlanmalı veya şifreli bellek kullanımı zorunlu hale getirilmelidir. Google Drive paylaşım izinleri sıkılaştırılmalı, DLP çözümleri devreye alınmalı ve tüm veri hareketleri merkezi olarak denetlenmelidir.
- **Risk Seviyesi:** High

Bulgu 2 - Desteklenmeyen İşletim Sistemlerinin Kullanımı

- **ISO 27001 Referansı:** A.12.6.1 (Teknik Açıklıkların Yönetimi)
- **Eksiklik:** Çalışan cihazlarının %30'unda (ör. Windows 7) ve bazı sunucularda (Windows Server 2012 R2, Windows Server 2008 R2, Ubuntu 18.04 LTS) resmi desteği sona ermiş işletim sistemleri kullanılmaktadır. Windows Server 2008 R2 sistemlerinde kritik güvenlik

güncellemelerinin uygulanmadığı ve SMBv1 gibi eski protokollerin açık olabileceği görülmüştür.

- **Neden:** Güncelleme maliyetleri ve bazı uygulamaların yeni sürümlerle uyumsuzluğu nedeniyle eski sistemler güncellenmemiş, geçiş ertelenmiştir.
- **Etki:** Bu sistemler artık güvenlik yaması alamadıkları için bilinen kritik güvenlik açıklarına (CVE) karşı savunmasızdır. RDP, SMB ve IIS gibi servisler üzerinden istismar edilerek ağın tamamının ele geçirilmesine yol açabilir.
- **Öneri:** Tüm desteklenmeyen sistemler en kısa sürede güncel ve desteklenen sürümlere yükseltilmelidir. Geçiş tamamlanana kadar riskli sistemler ağdan izole edilmeli, yalnızca gerekli servisler açık bırakılmalı ve SMBv1 kapatılmalıdır. Geçiş ertelenecekse riskin yönetim tarafından resmi olarak kabul edilmesi sağlanmalıdır.
- **Risk Seviyesi:** Critical

Bulgu 3 - Yetersiz Maaş Yönetimi ve Veri Güvenliği Eksikliği

- **ISO 27001 Referansı:** A.8.2.1 (Bilginin Sınıflandırılması), A.9.4.1 (Bilgiye Erişimin Kısıtlanması), A.18.1.4 (Kişisel Verilerin Gizliliği ve Korunması)
- **Eksiklik:** Maaş verileri herhangi bir erişim kontrolü veya şifreleme olmayan Excel dosyaları üzerinden manuel olarak yönetilmektedir.
- **Neden:** Kurumsal ve güvenli bir maaş yönetim yazılımı (Payroll / ERP) benimsenmemiştir.
- **Etki:** Verilerin yetkisiz kişiler tarafından görüntülenmesi veya değiştirilmesi riski çok yüksektir. Dosyaların USB ile taşınması sızıntı riskini artırmaktadır. Bu durum KVKK ihlali ve ciddi finansal riskler oluşturur.
- **Öneri:** Kurumsal bir maaş yönetim yazılımına geçiş planı yapılmalıdır. Kısa vadede Excel dosyaları şifrelenmeli ve yalnızca yetkili kullanıcıların erişebildiği güvenli ağ dizinlerinde saklanmalıdır.
- **Risk Seviyesi:** High

Bulgu 4 - Güvensiz ve Otomatik Olmayan Yedekleme Süreci

- **ISO 27001 Referansı:** A.12.3.1 (Bilgi Yedekleme)
- **Eksiklik:** Kritik veri yedeklemeleri (maaş sistemi dahil) haftalık ve manuel olarak USB belleklere yapılmaktadır. Düzenli geri yükleme testleri gerçekleştirilmemektedir.
- **Neden:** Otomatik, merkezi ve güvenli bir yedekleme çözümü bulunmamaktadır.
- **Etki:** Yedekleme medyası kaybolur veya bozulursa kritik verilerin kurtarılması mümkün olmayabilir. Fidye yazılımı saldırısı durumunda iş sürekliliği ciddi şekilde tehlikeye girer.
- **Öneri:** Otomatik ve merkezi bir yedekleme sistemi kurulmalıdır. Yedekler şifrelenmeli, hem bulutta hem on-prem ortamda saklanmalı ve geri yükleme testleri periyodik olarak gerçekleştirilmelidir.
- **Risk Seviyesi:** High

4.2 Kullanılan Cihazlar ve Sistemler

Bulgu 5 - Dağınık ve Entegre Olmayan Sistem Yönetimi

- **ISO 27001 Referansı:** A.5.1.1 (Bilgi Güvenliği Politikaları), A.12.4.1 (Olay Kaydı)
- **Eksiklik:** Güvenlik politikaları ve yönetim süreçleri farklı platformlarda (AWS, On-Prem, Google Workspace, USB) dağınık şekilde yönetilmektedir. Merkezi bir kimlik ve log yönetimi çözümü yoktur.
- **Neden:** Bütünleşik bir güvenlik stratejisi ve mimarisi oluşturulmamıştır.
- **Etki:** Platformlar arasında farklı güvenlik seviyeleri oluşmakta ve saldırı yüzeyi genişlemektedir. Merkezi denetim ve izleme eksikliği güvenlik olaylarına müdahaleyi geciktirir.
- **Öneri:** Tüm sistemler için ortak güvenlik politikaları oluşturulmalı, merkezi bir kimlik yönetimi (IAM) çözümü ve log takibi için bir SIEM sistemi uygulanmalıdır.
- **Risk Seviyesi:** Medium

Bulgu 6 - SSH Sunucusunda Zayıf Güvenlik Ayarları

- **ISO 27001 Referansı:** A.13.1.1 (Ağ Kontrolleri), A.9.4.2 (Güvenli Oturum Açma Prosedürleri)
- **Eksiklik:** Ubuntu 18.04 LTS web sunucusunda SSH portu varsayılan (22) olarak bırakılmış, SSH erişiminde MFA kullanılmamakta, ufw güvenlik duvarı pasif durumda ve otomatik güncellemeler kapalıdır. Sunucuda root dahil 6 kullanıcı bulunmakta ve root erişimi doğrudan açıktır.
- **Neden:** Sunucu kurulumu sırasında güvenlik ayarları varsayılan haliyle bırakılmış, güvenlik duvarı ve güncelleme politikaları uygulanmamıştır.
- **Etki:** Varsayılan port ve kapalı güvenlik duvarı, sunucuyu otomatik brute force saldırılarına ve port taramalarına açık hale getirir. Root ve kritik kullanıcı hesaplarının ele geçirilmesi durumunda web uygulaması ve veritabanına yetkisiz erişim sağlanabilir.
- **Öneri:** ufw etkinleştirilerek yalnızca gerekli portlar açılmalıdır. SSH'ta root ile doğrudan giriş kapatılmalı, anahtar tabanlı kimlik doğrulama ve mümkünse MFA kullanılmalı, brute force koruması (ör. fail2ban) eklenmelidir. SSH portu varsayılandan farklı bir porta taşınabilir ve otomatik güvenlik güncellemeleri açılmalıdır.
- **Risk Seviyesi:** High

Bulgu 7 - macOS Ventura Güvenlik Açıkları ve Yama Yönetimi Eksikliği

- **ISO 27001 Referansı:** A.12.6.1 (Teknik Açıklıkların Yönetimi)
- **Eksiklik:** Kurumda kullanılan macOS Ventura cihazları için merkezi ve düzenli bir yama yönetimi politikası bulunmamaktadır. Cihazlarda Kernel, libxpc ve Safari gibi bileşenlerde yayımlanmış güvenlik açıkları bulunmaktadır.

- **Neden:** Cihazlar merkezi bir güvenlik politikası altında yönetilmemektedir.
- **Etki:** Güncel olmayan macOS sistemlerindeki açıklar yetkisiz kod çalıştırılmasına veya veri sızıntısına yol açabilir.
- **Öneri:** Tüm macOS cihazlarına en son güvenlik güncellemeleri uygulanmalı, mümkünse desteklenen daha yeni sürümlere yükseltilmelidir. Kurum tüm cihazlar için merkezi bir yama yönetimi politikası oluşturmalıdır.
- **Risk Seviyesi:** Medium

4.3 NextID Yönetim Platformu

Bulgu 8 - Kritik Kullanıcılarda Çok Faktörlü Kimlik Doğrulama (MFA) Eksikliği

- **ISO 27001 Referansı:** A.9.4.2 (Güvenli Oturum Açma Prosedürleri), A.9.2.3 (Ayrıcalıklı Erişim Haklarının Yönetimi)
- **Eksiklik:** NextID platformunda Workspace, AWS ve CRM sistemlerinin tamamına erişimi olan IT yöneticisi (emre.kaya) ile Workspace, CRM ve Payroll erişimi olan servis hesabının (admin@nexcorp) MFA'sı kapalı durumdadır. Servis hesabının son giriş tarihi bilinmemektedir. Pazarlama kullanıcısı (can.yildiz) için de MFA kapalıdır.
- **Neden:** Şirket genelinde MFA kullanımını zorunlu kılan bir politika uygulanmamış, servis hesapları izleme olmadan yönetilmektedir.
- **Etki:** Kimlik avı veya parola sızıntısı durumunda bu hesapların ele geçirilmesi, tüm bulut ve yerel sistemlere yetkisiz erişim sağlanmasına yol açabilir.
- **Öneri:** Tüm yönetici ve kritik servis hesapları için MFA derhal zorunlu hale getirilmelidir. Servis hesapları için ayrı ve güvenli kimlik bilgisi / anahtar yönetimi uygulanmalı, son kullanım tarihleri ve logları kayıt altına alınmalıdır. Tüm kurumsal hesaplar için MFA politikası oluşturulmalı ve periyodik denetimlerle uygulanması sağlanmalıdır.
- **Risk Seviyesi:** Critical

Bulgu 9 - Ayrılan Kullanıcı Hesaplarının Aktif Kalması

- **ISO 27001 Referansı:** A.9.2.6 (Erişim Haklarının Kaldırılması veya Düzenlenmesi)
- **Eksiklik:** İşten ayrılan personel "ayse.ozdemir" hesabının AWS üzerinde MFA kapalı olarak ve Linux sunucusunda /bin/bash shell ve /home/ayse dizini ile hala aktif olduğu tespit edilmiştir.
- **Neden:** Çalışanların işten ayrılış süreçleri (offboarding) standardize edilmemiş ve merkezi olarak yürütülmemektedir.
- **Etki:** İşten ayrılan personelin hesabı kötü niyetli kişiler tarafından ele geçirilirse kurumsal sistemlere ve verilere izinsiz erişim sağlanabilir.
- **Öneri:** İşten ayrılan çalışanların tüm sistemlerdeki hesapları derhal kapatılmalı veya shell / usr/sbin/nologin olarak değiştirilmelidir. Hesap kapatma ve yetki iptali adımlarını içeren standart bir offboarding prosedürü oluşturulmalı ve uygulanmalıdır.

- **Risk Seviyesi:** Critical

4.4 Ek Sistemler ve Yetkilendirme

Bulgu 10 - Linux Sunucusunda Yetersiz Kullanıcı Yönetimi

- **ISO 27001 Referansı:** A.9.2.1 (Kullanıcı Kaydı ve Kaydın Silinmesi), A.9.4.1 (Bilgiye Erişimin Kısıtlanması)
- **Eksiklik:** Ubuntu web sunucusunda "mehmet" kullanıcısının home dizini /home/can olarak yanlış atanmış ve "can" kullanıcısı ile aynı dizini paylaşmaktadır.
- **Neden:** Sunucuya kullanıcı ekleme ve yetkilendirme süreçlerinde kontrol ve doğrulama eksikliği bulunmaktadır.
- **Etki:** Yanlış atanan home dizinleri kullanıcılar arasında yetkisiz dosya erişimine ve veri bütünlüğü ihlallerine yol açabilir.
- **Öneri:** Tüm kullanıcıların home dizinleri ayrı ve doğru şekilde atanmalı, dizin izinleri yalnızca ilgili kullanıcıya açık olacak şekilde sıkılaştırılmalıdır (chmod 700). Kullanıcı oluşturma prosedürü gözden geçirilmelidir.
- **Risk Seviyesi:** Medium

Bulgu 11 - Fatura Onay Sistemi: Görevler Ayrılığı (SoD) İhlali

- **ISO 27001 Referansı:** A.6.1.2 (Görevlerin Ayrılığı)
- **Eksiklik:** Fatura Onay Sistemi'nde "can.kara" kullanıcısı hem fatura oluşturma hem de fatura onaylama yetkisine sahiptir. Üst limit kontrolleri ve otomatik onay mekanizması sınırlıdır.
- **Neden:** Rol bazlı erişim kontrolleri ve yetki denetimi düzenli olarak yapılmamaktadır.
- **Etki:** Görevlerin ayrılmaması sahte veya yetkisiz fatura oluşturma ve onaylama, finansal dolandırıcılık ve kasıtlı hata riskini artırır.
- **Öneri:** Fatura oluşturma ve onaylama yetkileri birbirinden ayrılmalıdır. Görevler Ayrılığı matrisi oluşturulmalı, üst limit uyarıları eklenmeli ve tüm işlemler loglanarak periyodik olarak denetlenmelidir.
- **Risk Seviyesi:** High

Bulgu 12 - İnsan Kaynakları Portalı: Aşırı Yetki ve Veri Sızıntısı Riski

- **ISO 27001 Referansı:** A.9.2.3 (Ayrıcalıklı Erişim Haklarının Yönetimi), A.9.2.5 (Kullanıcı Erişim Haklarının Gözden Geçirilmesi)
- **Eksiklik:** Yazılım Geliştirici olarak tanımlı "emre.kaya" kullanıcısının ve Stajyer (gizem.aydın) gibi personelin görev tanımının ötesinde İnsan Kaynakları Portalı'ndaki hassas verilere (maaş bilgileri, tüm çalışan listesi) erişimi bulunmaktadır.

- **Neden:** En Az Ayrıcalık (Least Privilege) prensibi uygulanmamış, periyodik yetki gözden geçirme süreci bulunmamaktadır.
- **Etki:** Kritik kişisel ve maaş bilgileri gereksiz erişime sahip kişiler tarafından görüntülenebilir veya sızdırılabilir. Bu durum veri gizliliği ihlaline ve KVKK uyumsuzluğuna yol açar.
- **Öneri:** Tüm kullanıcı yetkileri görev tanımlarına göre gözden geçirilmeli ve en az ayrıcalık prensibi uygulanmalıdır. Stajyer ve geliştiricilerin hassas verilere erişimi kısıtlanmalı, yetkiler üç ayda bir gözden geçirilmelidir.
- **Risk Seviyesi:** High

Bulgu 13 - Sudo Güvenlik Açığı ve Yetki Yükseltme Riski

- **ISO 27001 Referansı:** A.12.6.1 (Teknik Açıklıkların Yönetimi)
- **Eksiklik:** Ubuntu sunucusunda kullanılan sudo paketi güncel değildir ve bilinen güvenlik açıklarını (CVE) içermektedir.
- **Neden:** Güvenlik yamaları ve güncellemeler düzenli olarak uygulanmamaktadır.
- **Etki:** Yerel bir kullanıcı bu güvenlik açığını kullanarak sistemde ayrıcalık kazanabilir ve root yetkisi elde edebilir. Bu durum sistemin bütünlüğünü ve gizliliğini ciddi şekilde tehlikeye atar.
- **Öneri:** Sudo paketi en kısa sürede güncel sürüme yükseltilmelidir. Tüm sistemler için otomatik yama yönetimi ve düzenli güvenlik taramaları sağlanmalıdır.
- **Risk Seviyesi:** High

Bulgu 14 - Zayıf Parola Hashleme Algoritması Kullanımı

- **ISO 27001 Referansı:** A.9.4.3 (Parola Yönetim Sistemi), A.10.1.1 (Kriptografik Kontrollerin Kullanımına İlişkin Politika)
- **Eksiklik:** Ubuntu sunucusundaki /etc/shadow dosyasında kullanıcı parolaları için MD5-crypt (1) gibi eski ve zayıf bir hashleme algoritması kullanılmaktadır.
- **Neden:** Sistem modern ve güvenli bir parola hashleme yöntemi kullanacak şekilde yapılandırılmamıştır.
- **Etki:** /etc/shadow dosyasını ele geçiren bir saldırgan çevrimdışı parola kırma (offline brute force) saldırılarıyla parolaları kısa sürede elde edebilir.
- **Öneri:** Sistem SHA-512 (6) veya yescrypt (y) gibi güncel ve hesaplama maliyeti yüksek algoritmaları kullanacak şekilde yapılandırılmalı, tüm kullanıcıların parolaları yenilenerek yeni algoritmayla hashlenmelidir. Parola politikası bu kuralı içerecek şekilde güncellenmelidir.
- **Risk Seviyesi:** High

Bulgu 15 - Tutarsız Rol Tanımı ile Ayrıcalıklı Erişim ve Hesap Verebilirlik İhlali

- **ISO 27001 Referansı:** A.9.2.3 (Ayrıcalıklı Erişim Haklarının Yönetimi), A.6.1.2 (Görevlerin Ayrılığı), A.6.1.1 (Bilgi Güvenliği Rolleri ve Sorumlulukları)
- **Eksiklik:** "emre.kaya" kullanıcısı NextID platformunda Workspace, AWS ve CRM sistemlerinin tamamına erişimi olan IT Admin olarak, İnsan Kaynakları Portalı'nda ise Yazılım Geliştirici olarak tanımlıdır. Aynı kişinin hem yönetici (privileged) hesabı hem geliştirici rolü bulunmakta, hesabında MFA kapalıdır ve İK Portalı'ndaki maaş verilerine de erişebilmektedir. Kullanıcının gerçek görevini ve bu yetkilerin onayını gösteren bir kayıt sunulmamıştır.
- **Neden:** Kullanıcı rollerinin HR kayıtlarıyla eşleştirilmemesi, ayrıcalıklı hesapların ayrı tutulmaması ve rol bazlı erişim yönetiminin (RBAC) sistemler arasında tutarlı uygulanmaması.
- **Etki:** Kimin hangi yetkiyle ne yaptığı izlenemez ve hesap verebilirlik (accountability) ortadan kalkar. Kodu geliştiren kişinin aynı zamanda üretim ve bulut ortamında yönetici olması görevler ayrılığını (SoD) ihlal eder; yetkisiz değişiklik veya veri erişimi fark edilmeden yapılabilir. Hesabın ele geçirilmesi tüm kritik sistemlerin ele geçirilmesi anlamına gelir.
- **Öneri:** Kullanıcının gerçek görevi HR kayıtlarıyla netleştirilmeli ve tüm sistemlerde tek bir role göre yetkilendirilmelidir. Yönetici yetkileri günlük kullanılan hesaptan ayrı, MFA'lı bir ayrıcalıklı hesapta (ör. adm-emre.kaya) tutulmalı, geliştirici ile üretim yöneticisi rolleri ayrılmalıdır. Ayrıcalıklı hesaplar için onay süreci ve üç ayda bir yetki gözden geçirmesi uygulanmalı, tüm ayrıcalıklı işlemler loglanmalıdır.
- **Risk Seviyesi:** High

5. Risk Değerlendirmesi

No	Bulgu	Risk Seviyesi	Olası Etki
2	Desteklenmeyen işletim sistemleri	Critical	Bilinen CVE'lerle ağın ele geçirilmesi, fidye yazılımı
8	Kritik kullanıcılarda MFA yok	Critical	Tek parola ile tüm bulut ve yerel sistemlere erişim
9	Ayrılan personel hesabı aktif	Critical	AWS ve sunucuya yetkisiz erişim
1	Kontrolsüz veri paylaşımı, DLP yok	High	Veri sızıntısı, KVKK ihlali
3	Maaş verileri korumasız Excel'de	High	Kişisel veri ifşası, finansal manipülasyon
4	Manuel USB yedekleme, test yok	High	Veri kaybı, iş sürekliliğinin kesilmesi

No	Bulgu	Risk Seviyesi	Olası Etki
6	SSH / ufw / güncelleme ayarları zayıf	High	Brute force ile sunucunun ele geçirilmesi
11	Fatura sisteminde SoD ihlali	High	Sahte fatura ve finansal kayıp
12	İK portalında aşırı yetki	High	Maaş ve kişisel veri sızıntısı
13	Güncel olmayan sudo paketi	High	Yerel kullanıcının root yetkisi kazanması
14	MD5-crypt parola hashleri	High	Çevrimdışı parola kırma
15	Tutarsız rol, ayrıcalıklı erişim ve SoD ihlali	High	Hesap verebilirliğin kaybı, izlenemeyen yetkisiz işlem
5	Dağınık yönetim, merkezi IAM / log yok	Medium	Olaylara geç müdahale, tutarsız güvenlik seviyesi
7	macOS yama yönetimi yok	Medium	Uç noktalarda kod çalıştırma
10	Yanlış home dizini ataması	Medium	Kullanıcılar arası yetkisiz dosya erişimi

6. Yönetim Sunumu

Sayın NextCorp Yönetimi,

Gerçekleştirdiğimiz bilgi güvenliği denetimi sonucunda ulaştığımız temel bulgular aşağıda özetlenmiştir:

1. **Kimlik ve Erişim Yönetimi:** En kritik hesaplarda MFA bulunmamakta, işten ayrılan personelin hesabı açık kalmakta, aynı kişi farklı sistemlerde farklı rollerle tanımlı olabilmekte ve yetkiler görev tanımlarına göre verilmemektedir. Tek bir parolanın ele geçirilmesi tüm sistemlerin ele geçirilmesi anlamına gelmektedir.
2. **Eski ve Yamasız Sistemler:** Destek dışı işletim sistemleri, güncel olmayan paketler ve merkezi bir yama yönetiminin olmaması kurumu bilinen açıklara karşı savunmasız bırakmaktadır.
3. **Veri Koruma ve Süreklilik:** Maaş gibi hassas veriler korumasız tutulmakta, veriler USB ile paylaşılıp yedeklenmekte ve yedeklerin geri dönülebilirliği test edilmemektedir.

Acil Aksiyon Planı (Öneri):

1. **Acil (İlk 30 Gün):**
    - Tüm yönetici ve servis hesaplarında MFA'nın zorunlu hale getirilmesi.

    - emre.kaya kullanıcısının rolünün netleştirilmesi ve yönetici yetkilerinin ayrı, MFA'lı bir hesaba taşınması.
    - Ayrılan personel hesaplarının tüm sistemlerde kapatılması ve offboarding prosedürünün yazılı hale getirilmesi.
    - Ubuntu sunucuda ufw'nin etkinleştirilmesi, root SSH girişinin kapatılması ve sudo paketinin güncellenmesi.

2. **Kısa Vade (İlk 90 Gün):**
    - Desteklenmeyen sistemlerin izole edilmesi ve yükseltme takviminin yönetim onayına sunulması.
    - Fatura Onay Sistemi ve İK Portalı yetkilerinin SoD ve en az ayrıcalık prensibine göre yeniden düzenlenmesi.
    - Maaş dosyalarının şifrelenmesi, otomatik ve şifreli yedekleme sistemine geçilmesi ve ilk geri yükleme testinin yapılması.

3. **Orta Vade (İlk 180 Gün):**
    - Merkezi IAM, SIEM ve yama yönetimi çözümlerinin devreye alınması.
    - Veri paylaşım politikası ve DLP çözümünün uygulanması, kurumsal maaş yönetim yazılımına geçiş.
    - ISO 27001 sertifikasyonu öncesinde bulguların kapatıldığının bağımsız olarak yeniden doğrulanması.

Ek-1: Denetim Sırasında Yönetime Yöneltilen Sorular

1. Yönetim ve Politika

- NextCorp'un resmi bir Bilgi Güvenliği Politikası var mı? Varsa en son ne zaman gözden geçirildi ve çalışanlara duyuruldu?
- ISO 27001 sertifikasyon hedefine ulaşmak için belirlenmiş bir yol haritası ve bu süreci yöneten sorumlu bir ekip var mı?
- Tüm bilgi varlıkları (sunucular, uygulamalar, veriler) için envanter yönetimi ve sınıflandırma (gizli, dahili, genel) süreçleri nasıl işliyor?

2. Kimlik ve Erişim Yönetimi

- Tüm kullanıcı ve servis hesapları için MFA'yı zorunlu kılan bir politika var mı? Uygulanışı nasıl denetleniyor?
- İşten ayrılan personelin tüm sistem ve uygulama erişimlerinin (örneğin AWS ve NextID) zamanında ve eksiksiz kapatıldığı nasıl garanti ediliyor? Bu süreci anlatan yazılı bir prosedür var mı?
- Fatura Onay Sistemi'ndeki gibi görevler ayrılığı (SoD) ilkesine aykırı durumları belirlemek için düzenli kontroller yapılıyor mu?

3. Güvenlik Açığı ve Yama Yönetimi

- Windows Server 2008 / 2012, Ubuntu 18.04 ve Windows 7 gibi desteklenmeyen işletim sistemleri için risk azaltma (izolasyon, sanal yama vb.) planları nelerdir?
- Uç nokta cihazları ve sunucular için merkezi bir yama yönetim sistemi kullanılıyor mu? Yamaların tüm cihazlara uygulandığını gösteren raporlar sunulabilir mi?
- Periyodik zafiyet taramaları yapılıyor mu? Bulunan kritik zafiyetler (örneğin sudo güvenlik açığı) için düzeltici faaliyetler nasıl takip ediliyor?

4. Veri Koruma ve İş Sürekliliği

- Maaş verilerinin tutulduğu Excel dosyalarında şifreleme ve erişim kontrolü nasıl sağlanıyor? Bu veriler kurumsal yedekleme politikasına dahil mi?
- Kritik veri yedeklerinin geri yüklenebilir olduğu nasıl doğrulanıyor? En son geri yükleme testi ne zaman yapıldı?
- Fidye yazılımı gibi bir siber olay durumunda operasyonel devamlılığı sağlayacak bir İş Sürekliliği ve Felaket Kurtarma planı var mı?

5. Sistem ve Log İzleme

- Tüm sunuculardaki (Windows, Ubuntu, AWS) güvenlik olay logları merkezi bir sistemde (SIEM) toplanıyor mu? Loglar ne kadar süre saklanıyor ve kimler tarafından inceleniyor?
- Sunucu güvenlik duvarı kurallarının (ufw gibi) ve SSH erişim ayarlarının varsayılan değerlerden farklı ve güvenli şekilde yapılandırıldığı nasıl kanıtlanıyor?
- Ubuntu sunucusunda MD5-crypt hash'leri yerine modern ve güvenli algoritmaların kullanılmasını sağlamak için bir plan var mı?